

LABORATORIO VIRTUAL

Simulación de ataque, detección con SIEM y respuesta a incidentes

Autor: Franco Etienne Vela Pérez

Estudiante de Ingeniería Civil Informática de Universidad Católica del Maule

Agosto 2026

Tecnologías: pfSense · Wazuh · Kali Linux · Ubuntu Server/Desktop · VirtualBox

Tabla de contenidos

Tabla de contenidos	2
1. Resumen ejecutivo	3
2. Introducción y objetivos	3
3. Alcance y consideraciones éticas	4
4. Arquitectura de la solución	4
4.1 Direccionamiento IP	5
5. Configuración de la infraestructura	5
5.1 Firewall perimetral — pfSense 2.8.1-RELEASE	5
5.2 Servidor Wazuh (SIEM)	6
5.3 Endpoint objetivo — Ubuntu Desktop	7
5.4 Estación atacante — Kali Linux	7
6. Metodología del ataque simulado	7
6.1 Fase de reconocimiento	8
6.2 Fase de explotación — Fuerza bruta	8
6.3 Resultado del ataque	8
7. Detección — Plataforma Wazuh (SIEM)	9
8. Mapeo a MITRE ATT&CK	10
9. Fase de respuesta y contención	11
10. Desafíos técnicos y aprendizajes	11
11. Limitaciones y trabajo futuro	12
12. Conclusiones	12

1. Resumen ejecutivo

Este documento describe el diseño, implementación y resultados de un laboratorio virtual de ciberseguridad orientado a demostrar competencias prácticas en administración de infraestructura de red, hardening, detección de amenazas y respuesta a incidentes. El proyecto simula un entorno corporativo reducido compuesto por un firewall perimetral (pfSense), un servidor SIEM (Wazuh) y un endpoint objetivo (Ubuntu Desktop), sobre el cual se ejecutó un ataque controlado de reconocimiento y fuerza bruta desde una estación atacante (Kali Linux) ubicada en un dispositivo físico independiente.

El ejercicio cubrió el ciclo completo de un incidente de seguridad: reconocimiento de servicios expuestos, explotación mediante fuerza bruta contra un servicio FTP mal configurado, detección automatizada por parte del SIEM (incluyendo una regla de correlación por umbral y el registro del inicio de sesión exitoso del atacante), y una fase de contención mediante una regla de bloqueo en el firewall perimetral, verificada posteriormente.

Más allá del resultado final, este informe documenta también el proceso de resolución de problemas enfrentado durante la construcción del laboratorio — errores de configuración de red, fallas de instalación por espacio en disco, problemas de sintaxis y de permisos a nivel de sistema operativo — como evidencia del proceso de aprendizaje y de la capacidad de diagnóstico aplicada durante el proyecto.

2. Introducción y objetivos

El objetivo principal de este proyecto es construir, de forma autodidacta, un entorno de laboratorio que permita practicar y demostrar habilidades técnicas relevantes para roles junior en ciberseguridad, replicando de forma simplificada la arquitectura típica de una red corporativa: perímetro protegido por firewall, segmentación de red, monitoreo centralizado de eventos y capacidad de respuesta ante incidentes.

Objetivos específicos:

- Diseñar e implementar una topología de red segmentada utilizando un firewall de nivel empresarial (pfSense).
- Desplegar una plataforma SIEM (Wazuh) para la recolección, correlación y visualización de eventos de seguridad.
- Configurar un endpoint con un servicio deliberadamente vulnerable, representativo de fallas de configuración comunes en entornos reales.
- Ejecutar un ataque simulado siguiendo una metodología estructurada (reconocimiento → explotación).
- Verificar la capacidad de detección del SIEM y correlacionar la evidencia entre las distintas fuentes de la infraestructura.
- Aplicar una medida de contención en el firewall en respuesta a la detección, cerrando el ciclo completo de manejo de incidentes.

3. Alcance y consideraciones éticas

Todo el ejercicio se desarrolló íntegramente dentro de un entorno aislado y controlado, compuesto por máquinas virtuales y un equipo físico adicional de mi propiedad, con fines exclusivamente educativos. En ningún momento se dirigió tráfico de ataque hacia sistemas, redes o servicios de terceros.

El alcance del proyecto fue ajustado durante su desarrollo respecto al planteamiento inicial. Originalmente se contempló un segundo endpoint Windows y una interfaz de firewall dedicada (OPT1) para aislar completamente a la estación atacante. Por razones de tiempo y de simplicidad operativa, el alcance se redujo a un único endpoint (Ubuntu Desktop) y la estación Kali se implementó en un equipo físico independiente, conectado a la red doméstica que actúa como "zona externa" (WAN) del firewall. Esta decisión se documenta y justifica en la sección 11 (Limitaciones y trabajo futuro).

4. Arquitectura de la solución

La siguiente figura muestra la topología final implementada. El firewall pfSense separa la red doméstica (WAN, que en este ejercicio cumple el rol de "red externa/no confiable" donde se ubica el atacante) de la red interna (LAN), donde residen el servidor Wazuh y el endpoint objetivo.

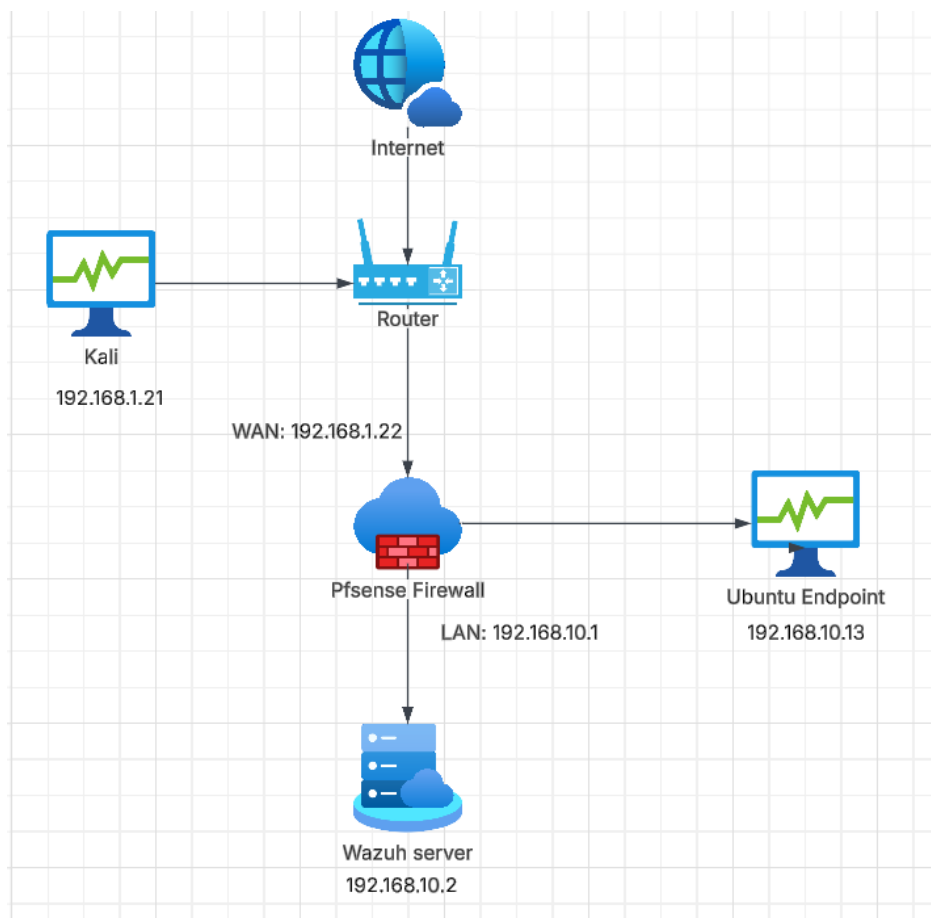


Figura 1. Diagrama de arquitectura de red del laboratorio.

4.1 Direccionamiento IP

Dispositivo	Rol	Dirección IP	Asignación
pfSense (WAN)	Firewall perimetral — interfaz externa	192.168.1.22	DHCP (red doméstica)
pfSense (LAN)	Firewall perimetral — interfaz interna / gateway	192.168.10.1	Estática
Wazuh Server	SIEM — manager, indexer y dashboard	192.168.10.2	DHCP reservado (static mapping), hostname "siem"
Ubuntu Endpoint	Objetivo del ataque — servicio FTP vulnerable	192.168.10.13	DHCP reservado (static mapping), hostname "endpoint1"
Kali Linux	Estación atacante — equipo físico independiente	192.168.1.21	DHCP (red doméstica)

5. Configuración de la infraestructura

5.1 Firewall perimetral — pfSense 2.8.1-RELEASE

La configuración de pfSense se realizó de forma incremental, partiendo del asistente de configuración inicial (wizard) y ajustando manualmente los parámetros de red, DHCP, DNS, NTP y reglas de firewall.

Configuración general

- Interfaz WAN en modo puente (bridged), obteniendo IP por DHCP de la red doméstica (192.168.1.110/24).
- Interfaz LAN reconfigurada a 192.168.10.1/24 (se corrigió un conflicto inicial en que ambas interfaces compartían el mismo subnet 192.168.1.0/24, lo cual generaba comportamiento errático de enrutamiento).
- Servidor DNS: 8.8.8.8 / 8.8.4.4, con "DNS Query Forwarding" activado en el DNS Resolver para que las consultas efectivamente se reenvíen a estos servidores en lugar de usar el resolver recursivo por defecto.
- Servidor NTP: ntp.shoa.cl (Servicio Hidrográfico y Oceanográfico de la Armada de Chile) como servidor primario, manteniendo un servidor del pool de pfSense como respaldo para asegurar redundancia. Zona horaria configurada en America/Santiago. La sincronización horaria consistente entre pfSense, el servidor Wazuh y el endpoint fue un factor clave para la correlación confiable de eventos durante el ataque.
- Usuario administrador dedicado creado; cuenta "admin" por defecto deshabilitada.
- Verificación de la opción "Block private networks" en la interfaz WAN, relevante por tratarse de un escenario de doble NAT (red doméstica dentro de rango privado).

Servidor DHCP (interfaz LAN)

- Rango de asignación dinámica: 192.168.10.10 – 192.168.10.50.
- Direcciones reservadas fuera del pool dinámico: .1 (gateway/firewall), .2–.9 (infraestructura con IP estática vía static mapping).
- Servidor DNS entregado por DHCP: únicamente 192.168.10.1.
- Reservas estáticas (static DHCP mapping) por dirección MAC para el servidor Wazuh (192.168.10.2) y el endpoint Ubuntu (192.168.10.13), garantizando direcciones predecibles para la configuración de agentes y reglas de firewall.

Reglas de firewall

Se mantuvieron las reglas por defecto de la interfaz LAN (anti-lockout y "LAN net → any"), sin modificaciones, dado que el tráfico entre los hosts de la LAN (Wazuh y el endpoint) no atraviesa el firewall al pertenecer al mismo segmento de red. Las reglas relevantes para el ejercicio se concentran en la interfaz WAN:

#	Interfaz	Origen	Destino	Protocolo / Puerto	Acción	Propósito
1	WAN	Host específico (diagnóstico)	This firewall (self)	ICMP	Permitir	Diagnóstico de conectividad hacia el firewall
2	WAN	IP de Kali (192.168.1.21)	WAN address	TCP / 21 (FTP)	Permitir + NAT	Redirección (port-forward) hacia el endpoint objetivo
3	WAN	IP de Kali (192.168.1.21)	Any	Any (TCP/UDP/ICMP)	Bloquear	Regla de contención posterior a la detección del ataque
—	WAN	Any	Any	Any	Bloquear (implícita)	Comportamiento por defecto de pfSense

La regla de contención (#3) se ubicó al inicio del listado de reglas de la interfaz WAN, dado que pfSense evalúa las reglas en orden y aplica la primera coincidencia — de haber quedado por debajo de las reglas de permiso, el bloqueo no habría tenido efecto. Todas las reglas relevantes se configuraron con registro de log activado, generando la evidencia utilizada en la sección 9.

La regla de NAT/port-forward permaneció deshabilitada durante la mayor parte de la configuración del laboratorio, habilitándose únicamente durante la ejecución controlada del ataque.

5.2 Servidor Wazuh (SIEM)

Especificaciones técnicas

Recurso	Configuración utilizada
Sistema operativo	Ubuntu Server 24.04, hostname "siem"
vCPU / RAM	2–4 vCPU / 4–8 GB RAM
Almacenamiento	Disco virtual de 40 GB (volumen LVM ampliado a capacidad completa)

Recurso	Configuración utilizada
Red	Adaptador de red interna (misma LAN que el endpoint), IP estática 192.168.10.2
Componentes instalados	Wazuh manager, indexer y dashboard (instalación "todo en uno", actualizaciones automáticas deshabilitadas)

Incidentes durante la instalación

La instalación de Wazuh presentó dos fallas relevantes que debieron diagnosticarse y resolverse:

- Falta de espacio en disco: el volumen lógico (LVM) creado durante la instalación de Ubuntu Server utilizaba únicamente 19 GB de los 40 GB disponibles en el disco físico, dejando el resto sin asignar al volume group. Esto provocó que la descarga del paquete wazuh-dashboard fallara a mitad de proceso ("No space left on device"), y el propio instalador ejecutó un rollback que removió los componentes ya instalados. Se resolvió extendiendo el volumen lógico al 100% del espacio disponible (lvextend + resize2fs).
- Paquete corrupto tras un segundo intento fallido: el paquete wazuh-manager quedó en un estado "Half-installed" se solucionó forzando la remoción y matar el proceso que lo provocaba, lo que permitió una instalación limpia y exitosa.

5.3 Endpoint objetivo — Ubuntu Desktop

Recurso	Configuración utilizada
Sistema operativo	Ubuntu Desktop 24.04, hostname "endpoint1"
vCPU / RAM	2 vCPU / 4 GB RAM
Almacenamiento	20 GB
Red	Adaptador de red interna (LAN), IP estática 192.168.10.13
Agente Wazuh	Instalado y registrado correctamente en el manager

Sobre este endpoint se instaló y configuró el servicio vsftpd, modificando deliberadamente las directivas anonymous_enable, local_enable, write_enable y anon_upload_enable para representar una configuración insegura común en auditorías reales (servidor FTP con credenciales de sistema operativo y escritura habilitada), sirviendo como vector de ataque para la fase de explotación.

5.4 Estación atacante — Kali Linux

Kali Linux se ejecutó sobre un equipo físico independiente al que aloja el resto del laboratorio, conectado a la misma red doméstica que la interfaz WAN de pfSense (dirección 192.168.1.21). Esta disposición se eligió para representar de forma más realista a un atacante externo, físicamente separado de la infraestructura objetivo, en lugar de simular el ataque con una máquina virtual adicional dentro del mismo hipervisor.

6. Metodología del ataque simulado

6.1 Fase de reconocimiento

Se utilizó nmap desde Kali para identificar el estado del servicio FTP expuesto por el endpoint a través del firewall:

```
nmap -sS -Pn -sCV -T5 -p21 -n 192.168.1.22
```

Flags usados: -sS realiza un SYN scan (medio sigiloso, sin completar el three-way handshake); -Pn omite el ping de descubrimiento, útil cuando un firewall bloquea ICMP; -sCV combina detección de versión (-sV) con scripts NSE por defecto (-sC); -T5 fija la plantilla temporal más agresiva (rápido pero ruidoso); -p21 limita el escaneo al puerto FTP; -n evita resoluciones DNS para acelerar.

Al usar este comando con la WAN del firewall (192.168.1.22), que es la que redirige el tráfico hacia el endpoint mediante la regla de NAT configurada, el escaneo confirmó el puerto 21/tcp en estado open con el servicio FTP identificado.

6.2 Fase de explotación — Fuerza bruta

Se ejecutó un ataque de fuerza bruta contra el servicio FTP utilizando Hydra:

```
hydra -l endpoint1 -P contrasenas.txt -t 1 -f -V ftp://192.168.1.22
```

Durante esta fase se identificaron y resolvieron dos obstáculos técnicos adicionales a la conectividad de red:

- Directiva PAM pam_listfile.so en /etc/pam.d/vsftpd, que consultaba el archivo /etc/ftpusers con política de denegación (sense=deny). El usuario del endpoint se encontraba listado en dicho archivo, provocando el rechazo sistemático de la autenticación independientemente de la validez de la contraseña. Se corrigió removiendo al usuario de la lista.
- Ajuste del nivel de paralelismo de Hydra (-t 1) para evitar el rechazo de conexiones concurrentes por parte de vsftpd.

6.3 Resultado del ataque

Tras corregir los puntos anteriores, el ataque de fuerza bruta se ejecutó exitosamente sobre el servicio FTP del endpoint, registrándose múltiples intentos fallidos de autenticación seguidos de un inicio de sesión exitoso con las credenciales correctas del usuario del sistema.


```

L$ nmap -sS -Pn -sCV -T5 -p21 -n 192.168.1.22
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 23:54 -0400
Nmap scan report for 192.168.1.22
Host is up (0.15s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
ftp-syst:
  STAT:
FTP server status:
  Connected to ::ffff:192.168.1.21
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  At session startup, client count was 1
  vsFTPd 3.0.5 - secure, fast, stable
End of status
ftp-anon: Anonymous FTP login allowed (FTP code 230)
Can't get directory listing: PASV IP 192.168.10.13 is not the same as 192.168.1.22
MAC Address: 04:EC:D8:87:10:E5 (Intel Corporate)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.29 seconds

(etienne@kali)~$
$ hydra -l endpoint1 -P /home/etienne/Descargas/texto.txt ftp://192.168.1.22
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organiza
tions, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-11 23:55:36
[DATA] max 16 tasks per 1 server, overall 16 tasks, 100 login tries (l:1/p:100), ~7 tries per task
[DATA] attacking ftp://192.168.1.22:21/
[21][ftp] host: 192.168.1.22 login: endpoint1 password: 123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-11 23:55:59

```

Figura 3. CLI Kali — uso de comando de nmap mostrando servicios vulnerables, y de hydra para ataque de fuerza bruta, filtrando las credenciales del endpoint

7. Detección — Plataforma Wazuh (SIEM)

El agente Wazuh instalado en el endpoint capturó los eventos de autenticación PAM generados durante el ataque, permitiendo su análisis desde el dashboard central.

Rule ID	Nivel	Descripción	Tipo
5503	5	PAM: User login failed	Evento individual de fallo de autenticación
5551	10	PAM: Multiple failed logins in a small period of time	Regla de correlación por umbral (patrón de fuerza bruta)

La regla 5551 constituye el hallazgo más relevante del ejercicio: a diferencia de la regla 5503 (que reporta eventos individuales), esta es una regla de correlación temporal que identifica el patrón de múltiples fallos consecutivos como indicio de un ataque de fuerza bruta, replicando el mecanismo de detección utilizado por SIEMs en entornos productivos. El dashboard registró un total de 828 eventos en la ventana de tiempo analizada, de los cuales 103 correspondieron a fallos de autenticación y 1 a un inicio de sesión exitoso — este último confirma que el ataque no solo fue detectado, sino que además culminó en un compromiso efectivo de la cuenta, completando la narrativa de intento de intrusión exitoso y detectado.

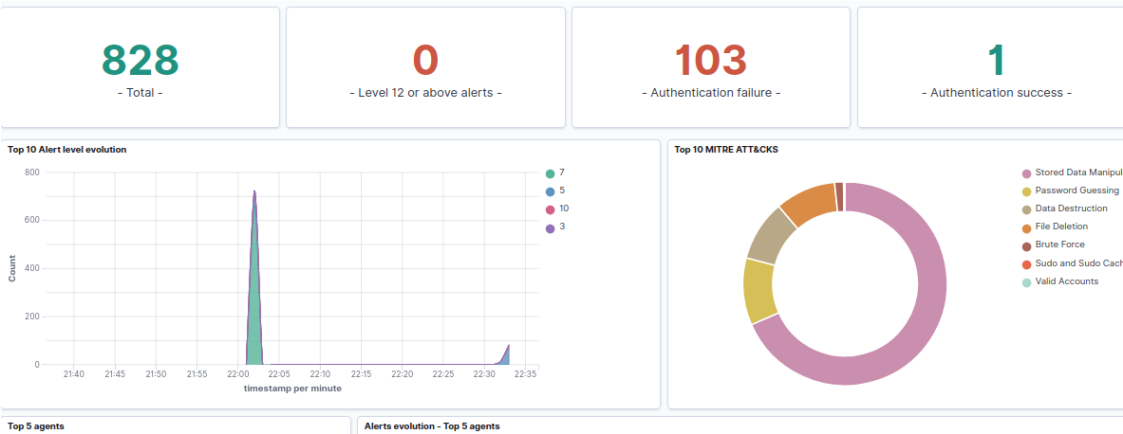


Figura 3. Panel de Threat Hunting de Wazuh — resumen del ataque detectado (828 eventos totales, 103 fallos de autenticación, 1 autenticación exitosa).

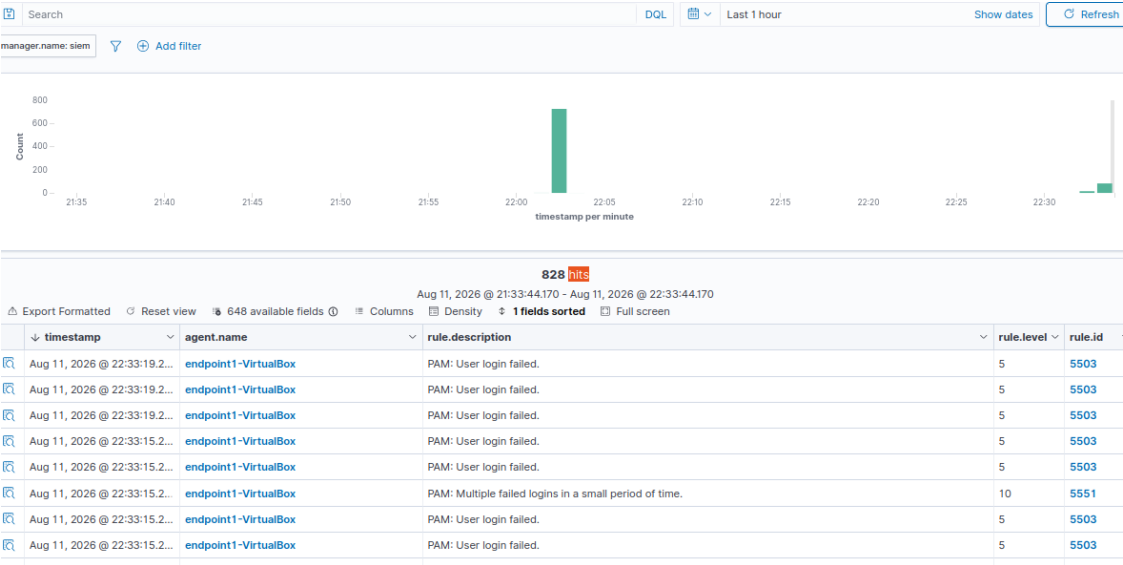


Figura 4. Detalle de eventos — alerta de nivel 10 (regla 5551) por múltiples intentos fallidos en un período acotado.

8. Mapeo a MITRE ATT&CK

Las técnicas empleadas durante el ejercicio se correlacionan con el framework MITRE ATT&CK de la siguiente forma:

Fase	Técnica	ID MITRE ATT&CK
Reconocimiento	Escaneo activo de puertos y servicios (nmap)	T1595 — Active Scanning
Acceso inicial / Credential Access	Adivinación de contraseñas por fuerza bruta contra FTP	T1110.001 — Brute Force: Password Guessing
Acceso inicial	Uso de credenciales válidas tras el compromiso	T1078 — Valid Accounts

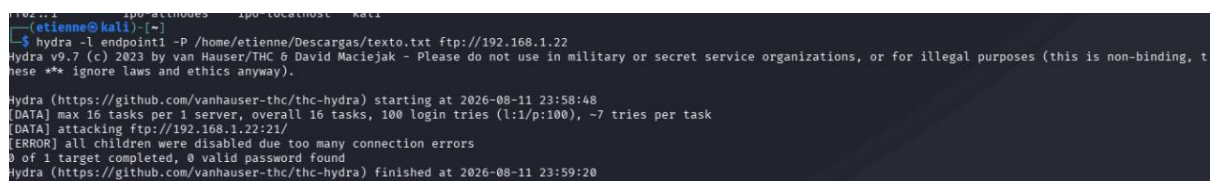
El panel de MITRE ATT&CK del dashboard de Wazuh también mostró categorías adicionales (Stored Data Manipulation, Data Destruction, File Deletion) que, tras revisión, corresponden a un rango temporal más amplio que el de la ventana específica del ataque analizado, y no forman parte del hallazgo principal documentado en este informe.

9. Fase de respuesta y contención

Como medida de respuesta ante la detección del ataque, se creó una regla de bloqueo explícita en la interfaz WAN del firewall, dirigida a la dirección IP de origen del atacante (192.168.1.21), con destino "any" (cubriendo tanto el tráfico dirigido al propio firewall como el redirigido por la regla de NAT hacia el endpoint) y registro de logs activado.

Un aspecto clave de esta configuración es el orden de evaluación de las reglas: pfSense procesa las reglas de arriba hacia abajo, aplicando la primera que coincide con el tráfico. La regla de bloqueo se ubicó al inicio del listado de reglas de la interfaz WAN, por encima de las reglas de permiso (ICMP y NAT/FTP), asegurando que el tráfico del atacante fuera descartado antes de alcanzar cualquier regla que lo permitiera.

Para verificar la efectividad de la medida, se repitió el ataque de fuerza bruta con Hydra tras la aplicación de la regla, confirmando que las conexiones ya no lograban establecerse — cerrando así el ciclo completo de detección, análisis y contención del incidente simulado.



```
etienne@kali: ~$ hydra -l endpoint1 -P /home/etienne/Descargas/texto.txt ftp://192.168.1.22
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these
** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-11 23:58:48
[DATA] max 16 tasks per 1 server, overall 16 tasks, 100 login tries (l:1/p:100), ~7 tries per task
[DATA] attacking ftp://192.168.1.22:21/
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-11 23:59:20
```

Figura 5. CLI Kali — Otro intento de ataque mediante hydra, fallando a causa de la nueva regla.

10. Desafíos técnicos y aprendizajes

La construcción de este laboratorio involucró la resolución de múltiples problemas técnicos no planificados, cuyo diagnóstico constituye en sí mismo una parte importante del valor formativo del proyecto:

- Conflicto de subredes entre las interfaces WAN y LAN de pfSense por dejar la configuración por defecto sin ajustar.
- Falta de espacio en disco por una asignación incompleta del volumen LVM durante la instalación de Ubuntu Server.
- Paquete del sistema en estado corrupto tras una instalación fallida.
- Error de sintaxis XML en la configuración del receptor de syslog de Wazuh (ossec.conf).
- Rechazo de autenticación FTP por la directiva PAM pam_listfile.so vinculada a /etc/ftpusers, no evidente a partir de una revisión superficial de vsftpd.conf.

En cada caso, el enfoque de diagnóstico consistió en aislar la variable específica de falla (capa de red, capa de sistema operativo, o capa de aplicación) antes de aplicar una corrección, evitando cambios especulativos.

11. Limitaciones y trabajo futuro

Este proyecto se planteó de forma incremental, priorizando dejar funcional el ciclo completo de ataque–detección–respuesta antes de expandir su alcance. Quedan identificadas las siguientes líneas de trabajo futuro:

- Reenvío de logs de pfSense hacia Wazuh vía syslog: el transporte de red fue verificado (captura de paquetes UDP/514 confirmada), pero no se completó la validación de que dichos eventos generen alertas visibles en el dashboard, por lo que se decidió postergar esta línea de trabajo.
- Incorporación de Suricata como IDS de red en pfSense, con reenvío de sus alertas a Wazuh, para complementar la detección basada en host (HIDS) con detección basada en red (NIDS).
- Monitoreo de integridad de archivos (FIM/syscheck) sobre el directorio raíz del servicio FTP, para detectar de forma independiente la manipulación de archivos en caso de explotar la función de carga anónima habilitada en vsftpd.
- Incorporación del log específico de vsftpd (vsftpd.log) como fuente adicional en la configuración del agente Wazuh, complementando los eventos de autenticación PAM ya capturados.
- Redacción de reglas de detección personalizadas (custom rules/decoders) en Wazuh, en particular para los eventos de pfSense, que no siempre son reconocidos por los decoders genéricos de syslog.

12. Conclusiones

El laboratorio implementado permitió cubrir de forma práctica el ciclo completo de un incidente de seguridad — desde el reconocimiento hasta la contención — utilizando herramientas y prácticas representativas de un entorno de Blue Team: segmentación de red mediante un firewall perimetral, monitoreo centralizado con una plataforma SIEM de uso extendido en la industria (Wazuh), y una metodología de ataque estructurada y documentada.

Más allá del resultado técnico final, el proceso de construcción del laboratorio —incluyendo los errores de configuración, fallas de instalación y su correspondiente diagnóstico— constituye evidencia concreta de capacidad de resolución de problemas en un entorno de infraestructura real, una competencia tan relevante para un perfil junior en ciberseguridad como el manejo de las herramientas mismas.

Las líneas de trabajo futuro identificadas (segundo endpoint, IDS de red, reglas de detección personalizadas) definen una hoja de ruta clara para continuar ampliando este proyecto como pieza central de portafolio técnico.